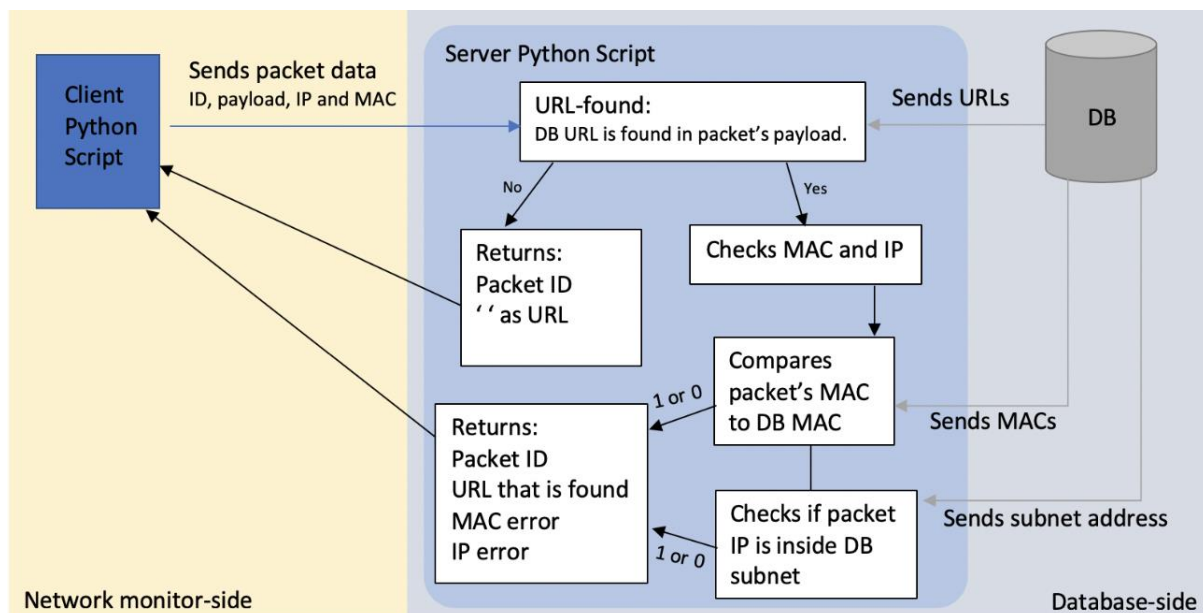


Opdracht Risk Assessment- Casus Hamerslag

De firma 'Hamerslag' heeft een online winkel waar ze doe-het-zelf (DIY) artikelen verkopen voor klusjes in huis. Het bedrijf heeft geen fysieke winkel en beschikt over een magazijn van waaruit alle bestellingen worden verzonden. Het magazijn is verantwoordelijk voor het inpakken van alle bestellingen en zorgt ervoor dat ze op tijd worden verzonden. Hiervoor heeft het bedrijf een onlinewebsite die draait vanaf een lokale server waarop alle bestellingen worden geüpload. Het magazijn heeft 12 inpakstations met 12 desktopcomputers waarop de werknemers de website moeten kunnen raadplegen om te weten welke bestellingen ingepakt moeten worden.

Hamerslag wil dat alleen de desktops in het magazijn toegang hebben tot de pagina met de bestellingen. Ze willen een eenvoudige netwerkmonitor gebruiken om te controleren wie toegang heeft tot de bestelpagina. Al het netwerkverkeer wordt gecontroleerd. Als een onbekend apparaat de bestelpagina bezoekt, moet dit worden gedetecteerd maar niet geblokkeerd (in zeldzame gevallen mogen werknemers vanaf een ander apparaat toegang hebben tot de bestelpagina, bijvoorbeeld als de desktop niet werkt). Wanneer er een ongeautoriseerde toegang tot de bestelpagina wordt gedetecteerd, wordt er een e-mail gestuurd naar de systeembeheerders.

Merk op dat de netwerkmonitor geen NIDS is, ze willen geen malware detecteren, ze willen eenvoudig monitoren wie toegang heeft tot hun bestelpagina. De volgende figuur toont hoe de netwerkmonitor is geïmplementeerd:



De netwerkmonitor stuurt datapakketten naar de databasekant. Daar wordt de URL gecontroleerd. Als de URL iets anders is dan de bestelpagina, wordt er niks mee gedaan. Als de URL overeenkomt met de bestelpagina, wordt het MAC-adres en het IP-adres gecontroleerd. De databasekant controleert vervolgens of het MAC-adres overeenkomt met een van de 12 desktops en/of het IP-adres binnen het geregistreerde subnet valt. Als een

van deze onwaar is, stuurt de netwerkmonitor aan de netwerkkant een e-mail naar de systeembeheerder.

Hamerslag heeft jouw adviesbureau ingehuurd om hen te helpen de risico's van het beschreven systeem te bepalen.

Opdracht

1. Ga naar: [https://owasp.org/www-community/OWASP Risk Rating Methodology](https://owasp.org/www-community/OWASP_Risk_Rating_Methodology) en lees de informatie door. Onthoud hierbij dat het doel is om overzicht te krijgen in risico's en mitigaties. Er is dus geen goed of fout, het gaat om je onderbouwing!
2. Voer de stappen van de OWASP Risk Rating Methodology uit
 - Step 1: Identifying a Risk
 - Step 2: Factors for Estimating Likelihood
 - Step 3: Factors for Estimating Impact
 - Step 4: Determining Severity of the Risk
 - Step 5: Deciding What to Fix
 - Step 6: Customizing Your Risk Rating Model

Denk aan risico's in de volgende categorieën:

1. **Bedreiging van externe aanvallers:** wat kan een aanvaller van buitenaf bereiken?
2. **Interne risico's:** wat kan een interne medewerker doen, die kwade bedoelingen heeft? Of wat kunnen medewerkers per ongeluk veroorzaken?
3. **Risico's van gegevensverlies of -diefstal:** wat zijn de gevolgen als de data lekt? Wat kan er gebeuren als logingegevens gestolen worden?

3. Werk de risico's uit in een overzichtelijke tabel, 1 voorbeeld is gegeven:

Risico	Impact	Kans	Mitigatie	CIA-attack
De netwerkmonitor heeft een storing.	Medium – iemand krijgt dan toegang tot de order-site zonder een alert te triggeren	Medium – het systeem draait lokaal en is zelfgebouwd, dit kan dus onbetrouwbaar zijn.	Implementeer een tweede systeem die het overneemt als de eerste tijdelijk niet werkt.	Confidentialiteit – iemand die geen toegang hoort te hebben kan dan de informatie zien zonder gedetecteerd te worden.
-	-	-	-	
-	-	-	-	
-	-	-	-	

4. Schrijf een kort advies aan Hamerslag waarin je de grootste risico's met jouw aanbevolen mitigatie benoemt.

